

DOCUMENTACIÓN TÉCNICA

Implementación de Seguridad Perimetral y WAF en FortiGate

Autor: Ranniel Sanchez Espinal

Matrícula: 2025-0889

Instituto Tecnológico de Las Américas (ITLA)

Fecha de Ejecución: Julio 2026

Tabla de Contenido

- Tabla de Contenido 2
- 1. Objetivo de la Red 3
- 2. Diseño de Topología y Direcccionamiento IP (Subnetting) 3
 - 2.1 Esquema de Subredes 3
 - 2.2 Nodos Finales Desplegados 3
- 3. Configuración de Interfaces y Enrutamiento Base..... 4
 - 3.1 Interfaces y DHCP 4
 - 3.2 Ruta por Defecto (Default Route) 4
- 4. Políticas de Firewall y NAT 5
 - 4.1 Política 1: Acceso a Internet (Usuarios) 5
 - 4.2 Política 2: Acceso a Servidores (Tráfico Interno HTTP) 5
- 5. Implementación de Perfiles de Seguridad (Security Profiles) 6
 - 5.1 Bloqueo de Redes Sociales y Dominios Específicos 6
 - 5.2 Bloqueo de Llamadas de WhatsApp (Application Control) 6
 - 5.3 Detección y Bloqueo de Escáneres de Red (IPS) 6
 - 5.4 Web Application Firewall (WAF) 6
- 6. Pruebas y Evidencias de Validación 7
 - Evidencia 1: Bloqueo de tráfico NO-HTTP hacia los Servidores..... 7
 - Evidencia 2: Filtrado de Redes Sociales y Dominios 7
 - Evidencia 3: Prevención de Ataques Web (WAF en Acción) 7
 - Evidencia 4: Registros de Auditoría (Logs de Seguridad) 8
- 7. Conclusiones..... 8

1. Objetivo de la Red

El propósito de este proyecto es diseñar, configurar y validar una infraestructura de red segura utilizando un appliance FortiGate. La topología exige la segmentación de la red en una LAN de Usuarios y una LAN de Servidores (DMZ), garantizando el acceso a Internet mediante NAT, y aplicando políticas restrictivas de seguridad de Capa 7. Todo el despliegue se realizó exclusivamente a través de la Interfaz Gráfica de Usuario (GUI) de FortiOS, cumpliendo con los requerimientos de filtrado web, control de aplicaciones, prevención de intrusiones (IPS) y firewall de aplicaciones web (WAF).

2. Diseño de Topología y Direccionamiento IP (Subnetting)

Para evitar el solapamiento de redes y mantener una jerarquía lógica, se tomó el bloque base 10.8.89.0/24 (utilizando el identificador 89) y se dividió utilizando VLSM de la siguiente manera:

2.1 Esquema de Subredes

Zona / Interfaz	Red Base	Máscara de Red	Rango IP Útil	IP Gateway
LAN-USUARIOS (Port 2)	10.8.89.0/25	255.255.255.128	.2 al .126	10.8.89.1
LAN-SERVIDORES (Port 3)	10.8.89.128/28	255.255.255.240	.130 al .142	10.8.89.129

2.2 Nodos Finales Desplegados

- **Máquina Atacante / Usuario:** Kali Linux (10.8.89.2 asignada por DHCP).
- **Servidor Web DMZ:** Parrot OS con Apache (10.8.89.130 configurada estáticamente).

3. Configuración de Interfaces y Enrutamiento Base

3.1 Interfaces y DHCP

Desde la GUI de FortiGate en la ruta **Network > Interfaces**, se aplicaron las siguientes configuraciones:

- **Port 1 (WAN):** Se configuró en modo DHCP Client para recibir la dirección IP pública del ISP y garantizar la salida a Internet.
- **Port 2 (LAN Usuarios):** Se asignó la IP 10.8.89.1/25. En la misma ventana, se habilitó el servicio DHCP Server, definiendo el Address Range de 10.8.89.2 a 10.8.89.126.
- **Port 3 (LAN Servidores):** Se asignó la IP 10.8.89.129/28. El DHCP se mantuvo deshabilitado por tratarse de un entorno de servidores.

3.2 Ruta por Defecto (Default Route)

Para permitir que el tráfico de las LANs alcance Internet, se configuró la tabla de enrutamiento en **Network > Static Routes**:

- **Destination:** 0.0.0.0/0
- **Gateway Address:** IP del Gateway del ISP.
- **Interface:** Port 1

4. Políticas de Firewall y NAT

Las reglas de acceso se configuraron bajo **Policy & Objects > Firewall Policy** bajo un esquema de "Zero Trust" (Denegación por defecto).

4.1 Política 1: Acceso a Internet (Usuarios)

Permite la navegación de los usuarios hacia el exterior aplicando traducción de direcciones.

Incoming Interface	Port 2 (LAN-USUARIOS)
Outgoing Interface	Port 1 (WAN)
Source / Destination / Service	all / all / ALL
Action	ACCEPT
NAT	Habilitado (Use Outgoing Interface Address)

4.2 Política 2: Acceso a Servidores (Tráfico Interno HTTP)

Permite estrictamente el tráfico web hacia la DMZ, bloqueando cualquier otro protocolo (incluyendo ICMP/Ping).

Incoming Interface	Port 2 (LAN-USUARIOS)
Outgoing Interface	Port 3 (LAN-SERVIDORES)
Source	all
Destination	Objeto Address creado para IP 10.8.89.130 (Servidor Web)
Service	HTTP (bloquea implícitamente todo lo demás)
Action	ACCEPT
NAT	Deshabilitado (comunicación interna enrutada)

5. Implementación de Perfiles de Seguridad (Security Profiles)

Todos los perfiles fueron aplicados a la política "Regla_Bloqueos_Estrictos" (para el tráfico de salida) y a "Acceso_Servidor_Web" (para el tráfico interno).

5.1 Bloqueo de Redes Sociales y Dominios Específicos

Se utilizó una combinación de DNS Filter y Web Filter para asegurar el bloqueo, incluso en tráfico HTTPS sin inspección profunda.

- **Ruta:** Security Profiles > DNS Filter

Acción: Se configuró un Static Domain Filter utilizando el tipo Wildcard y la acción Redirect to Block Portal para:

- *facebook.com*
- *instagram.com*
- *tiktok.com*
- *itla.edu.do* (bloqueando dominio principal y todos sus subdominios).

5.2 Bloqueo de Llamadas de WhatsApp (Application Control)

- **Ruta:** Security Profiles > Application Control
- **Acción:** Se localizaron las firmas específicas de WhatsApp dentro de la categoría Video/Audio. Se configuró la firma WhatsApp_Call con la acción explícita de Block, permitiendo la mensajería de texto pero cortando la transmisión de voz/video sobre IP.

5.3 Detección y Bloqueo de Escáneres de Red (IPS)

Para proteger la infraestructura de fases de reconocimiento (Reconnaissance).

- **Ruta:** Security Profiles > Intrusion Prevention
- **Acción:** Se editó el sensor IPS para incluir las firmas de las categorías Information Gathering y Network Scanners (herramientas como Nmap y Nessus). La acción predeterminada se cambió de Monitor a Block.

5.4 Web Application Firewall (WAF)

Se habilitó la protección de Capa 7 para el servidor Apache ubicado en la IP 10.8.89.130.

- **Ruta:** Security Profiles > Web Application Firewall

Acción: En la sección Signatures, se configuraron las siguientes categorías críticas en estado Enable y acción Block:

- SQL Injection
- Cross Site Scripting (XSS)
- Known Exploits (protección contra vulnerabilidades como Shellshock / CVEs publicados)
- Generic Attacks (protección contra Path Traversal / LFI)

6. Pruebas y Evidencias de Validación

Nota: las siguientes evidencias demuestran la efectividad de las configuraciones aplicadas.

Evidencia 1: Bloqueo de tráfico NO-HTTP hacia los Servidores

Prueba: Ejecución de `ping 10.8.89.130` desde Kali Linux.

Resultado esperado: 100% de pérdida de paquetes (Packet loss).

Explicación: La política de firewall Acceso_Servidor_Web restringe el servicio exclusivamente a HTTP (Puerto 80). El protocolo ICMP es descartado por el FortiGate.

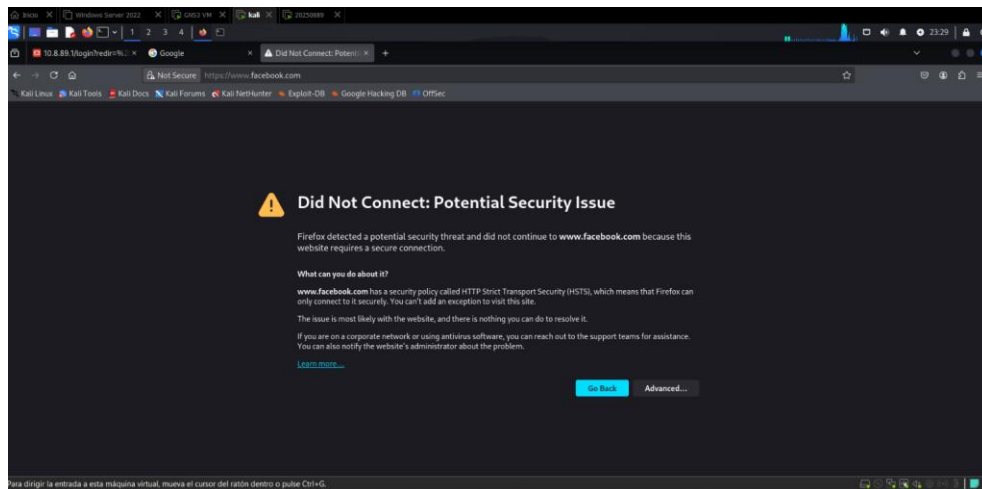
```
Archivo Acciones Editar Vista Ayuda
(ranniel@ranniel)-[~]
$ ping 10.8.89.130
PING 10.8.89.130 (10.8.89.130) 56(84) bytes of data.
^C
--- 10.8.89.130 ping statistics ---
225 packets transmitted, 0 received, 100% packet loss, time 229388ms
```

Evidencia 2: Filtrado de Redes Sociales y Dominios

Prueba: Intento de acceso a <https://www.facebook.com> y <https://www.tiktok.com> desde el navegador del cliente.

Resultado esperado: El navegador muestra "Did Not Connect: Potential Security Issue" o "Connection Timed Out".

Explicación: El DNS Filter intercepta la consulta DNS. Al intentar redirigir el tráfico hacia el portal de bloqueo de Fortinet en una conexión HTTPS con HSTS activado, el navegador rompe la conexión, logrando el bloqueo efectivo.



Evidencia 3: Prevención de Ataques Web (WAF en Acción)

Prueba: Ejecución de ataques simulados vía terminal hacia el servidor web. SQLi: `curl -v "http://10.8.89.130/?user=admin'%20OR%20'1'='1'"`

Resultado esperado: La terminal arroja el error: Recv failure: Conexión reiniciada por la máquina remota.

Explicación: El motor WAF analiza el payload HTTP, reconoce la firma de Inyección SQL y envía un paquete TCP RST (Reset), cortando la comunicación antes de que alcance al servidor Apache.

```
(ranniel@ranniel)-[~]
$ curl -v "http://10.8.89.130/?user=admin'%20OR%20'1'='1'"
* Trying 10.8.89.130:80 ...
* Connected to 10.8.89.130 (10.8.89.130) port 80
* using HTTP/1.x
> GET /?user=admin'%20OR%20'1'='1' HTTP/1.1
> Host: 10.8.89.130
> User-Agent: curl/8.11.0
> Accept: */*
>
* Request completely sent off
* Recv failure: Conexión reiniciada por la máquina remota
* closing connection #0
curl: (56) Recv failure: Conexión reiniciada por la máquina remota

(ranniel@ranniel)-[~]
```

Evidencia 4: Registros de Auditoría (Logs de Seguridad)

Prueba: Revisión del panel de administración del FortiGate tras lanzar los ataques.

Resultado esperado: Registros en color rojo en la categoría WAF / Forward Traffic.

Explicación: En Log & Report > Security Events se evidencia la traza forense del intento de ataque. El sistema registra la IP de origen (10.8.89.2), la IP de destino (10.8.89.130) y la acción ejecutada (blocked).

Result: Deny (all) Add Filter										Details	
Date/Time	Source	Device	Destination	Application Name	Result	Policy ID	Log Details				
8 minutes ago	10.8.89.2	00:0c:29:02:86:7f	10.8.89.130		Deny: UTM Blocked	Acceso_Servidor_Web (2)	Details				Security
42 minutes ago	10.8.89.2	00:0c:29:02:86:7f	10.8.89.130		Deny: UTM Blocked	Acceso_Servidor_Web (2)	Details				
51 minutes ago	10.8.89.2	00:0c:29:02:86:7f	10.8.89.130		Deny: UTM Blocked	Acceso_Servidor_Web (2)	Details				
Hour ago	10.8.89.2	00:0c:29:02:86:7f	57.144.162.1 (www.facebook.com)	Facebook	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
Hour ago	10.8.89.2	00:0c:29:02:86:7f	57.144.162.1 (www.facebook.com)	Facebook	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
Hour ago	10.8.89.2	00:0c:29:02:86:7f	57.144.162.1 (www.facebook.com)	HTTPS.BROWSER	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
Hour ago	10.8.89.2	00:0c:29:02:86:7f	57.144.162.1 (www.facebook.com)	HTTPS.BROWSER	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
Hour ago	10.8.89.2	00:0c:29:02:86:7f	57.144.162.1 (www.facebook.com)	HTTPS.BROWSER	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
2 hours ago	10.8.89.2	00:0c:29:02:86:7f	57.144.252.1 (www.facebook.com)	HTTPS.BROWSER	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
4 hours ago	10.8.89.2	00:0c:29:02:86:7f	151.101.193.91 (detectportal.firefox.com)	HTTPS.BROWSER	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
4 hours ago	10.8.89.2	00:0c:29:02:86:7f	151.101.191 (detectportal.firefox.com)	HTTPS.BROWSER	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
4 hours ago	10.8.89.2	00:0c:29:02:86:7f	141.109.161.71 (video.fortinet.com)	HTTPS.BROWSER	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
4 hours ago	10.8.89.2	00:0c:29:02:86:7f	141.109.161.71 (video.fortinet.com)	HTTPS.BROWSER	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
4 hours ago	10.8.89.2	00:0c:29:02:86:7f	141.109.161.71 (video.fortinet.com)	HTTPS.BROWSER	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
4 hours ago	10.8.89.2	00:0c:29:02:86:7f	151.101.65.91 (detectportal.firefox.com)	HTTPS.BROWSER	Deny: UTM Blocked	Internet_Usuarios (1)	Details				
4 hours ago	10.8.89.2	00:0c:29:02:86:7f	151.101.193.91 (detectportal.firefox.com)	HTTPS.BROWSER	Deny: UTM Blocked	Internet_Usuarios (1)	Details				

70.9 0%

☐ Highlight All ☐ Match Case ☐ Match Diacritics ☐ Whole Words

Attack Name	HTTPURI.SQLInjection
Attack ID	15621
Direction	outgoing
Log event original timestamp	178365472252441300
Event Type	signature
Hostname	10.8.89.130
Incident Serial No.	253756833
Level	■■■■■■■■
Profile Name	default
Reference	http://www.fortinet.com/ids/VID15621
Severity	■■■■■■
Sub Type	ips
Type	utm
Timezone	-0700
URL	/?user=admin' OR '1'='1'/?user=admin'%20OR%20'1'='1'

7. Conclusiones

La implementación validó de forma exitosa un esquema de defensa en profundidad sobre FortiGate, combinando segmentación de red (VLSM), políticas de firewall bajo el principio de mínimo privilegio, y perfiles de seguridad de Capa 7 (DNS Filter, Application Control, IPS y WAF). Las pruebas de validación confirmaron que el tráfico no autorizado ya sea por protocolo, dominio, aplicación o firma de ataque es identificado y bloqueado de forma consistente, y que cada evento queda registrado para su posterior auditoría forense.

Video Explicación

<https://youtu.be/HfligzNhnS4>